UNIVERSIDAD NACIONAL DE SAN AGUSTÍN DE AREQUIPA

FACULTAD DE INGENIERÍA DE PRODUCCIÓN Y SERVICIOS

ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS

AGENTE DE IA PARA LA GESTIÓN DE INCIDENTES Y BRECHAS DE DATOS PERSONALES

Trabajo de Investigación Formativa – 2026B

Asignatura: Auditoría de Sistemas

Docente: Edward Vicente Zarate Carlos

Integrantes:
Huacani Jara Denise Andrea
Luque Condori Luis Guillermo
Mollo Chuquicaña Dolly Yadhira
Pacheco Palo Fabiana Francinet
Valdivia Segovia Ryan Fabian

Arequipa – Perú
2026

ÍNDICE

1. INTRODUCCIÓN 4

1.1 Contexto y problema 4

1.2 Objetivos 4

1.3 Alcance 5

2. MARCO TEÓRICO Y NORMATIVO 5

2.1 Evento, incidente y brecha 5

2.2 ISO/IEC 27035: proceso de gestión de incidentes 5

2.3 ISO/IEC 27001, 27002 y 27701 6

2.4 NIST SP 800-61 Rev. 3 e ISO/IEC 27037 6

2.5 Marco legal peruano: D.S. N.° 016-2024-JUS 6

2.6 Metodología de severidad ENISA 7

2.7 Skills y agentes de IA 7

3. DE PROMPT A SKILL 8

3.1 Prompts originales 8

3.2 Carencias detectadas 8

3.3 Proceso de transformación 8

3.4 Resultado 9

4. CREACIÓN DE LOS SKILLS 9

4.1 Anatomía de un skill 9

4.2 Activación de los skills 9

4.3 Skill brecha-triaje 10

4.4 Skill brecha-evaluacion-severidad 11

4.5 Skill brecha-notificacion 11

4.6 Skill brecha-respuesta-cierre 12

5. CONSTRUCCIÓN DEL ASISTENTE 12

6. DISEÑO DEL AGENTE Y ORQUESTACIÓN 13

6.1 Ficha del agente 13

6.2 Flujo de decisión 13

6.3 Traspaso entre skills 14

6.4 Autonomía y control humano 14

7. PRUEBAS Y RESULTADOS 15

7.1 Casos de prueba 15

7.2 Resultados 15

7.3 Verificaciones transversales 16

7.4 Hallazgos y mejoras incorporadas 16
8. GUÍA DE USO 17
9. LIMITACIONES Y TRABAJO FUTURO 17
10. CONCLUSIONES 17
11. REFERENCIAS 18

1. INTRODUCCIÓN

1.1 Contexto y problema

Un Sistema de Gestión de Privacidad de la Información (**PIMS**, por sus siglas en inglés) es el conjunto de políticas, procesos y controles con el que una organización protege los datos personales que trata. La norma ISO/IEC 27701 lo define como una extensión de ISO/IEC 27001. Uno de sus procesos más críticos es la **gestión de incidentes y brechas de datos personales**: detectar que algo ocurrió, decidir si afecta datos personales, medir el daño para las personas, avisar a quien corresponde y aprender del incidente.

En el Perú este proceso tiene un plazo legal muy corto. El Reglamento de la Ley N.° 29733, aprobado por el **D.S. N.° 016-2024-JUS** y vigente desde el 30 de marzo de 2025, obliga a notificar a la Autoridad Nacional de Protección de Datos Personales (ANPD) **como máximo dentro de las 48 horas** posteriores a tomar conocimiento del incidente (art. 34.1), y a comunicarlo a los titulares afectados en el mismo plazo (art. 34.3). Omitir la notificación es una **infracción grave** (art. 133, num. 12).

En la práctica, cuando ocurre un incidente la organización trabaja bajo presión, con información incompleta, y suele resolver con consultas improvisadas. Esto produce decisiones inconsistentes, plazos mal calculados, notificaciones que omiten contenido obligatorio y acciones técnicas que destruyen evidencia.

1.2 Objetivos

Objetivo general. Construir un agente de inteligencia artificial, compuesto por skills reutilizables, que apoye al Oficial de Datos Personales en la gestión de incidentes y brechas de datos personales, con sustento en estándares internacionales (ISO/IEC 27035, 27001/27002, 27701, 27037, NIST SP 800-61r3) y en la normativa peruana (Ley N.° 29733 y D.S. N.° 016-2024-JUS).

Objetivos específicos:

1. Transformar las tareas que se resolvían con prompts sueltos en procesos reutilizables (**de prompt a skill**).
2. Crear cuatro skills con activación, estructura y pasos definidos, uno por fase del ciclo de ISO/IEC 27035 (**creación de skill**).
3. Dotar al asistente de identidad, instrucciones y una base de conocimiento normativa (**construcción de asistente**).
4. Diseñar un agente que orqueste los skills y controle el plazo de 48 horas.
5. Validar el funcionamiento con casos ficticios y criterios verificables.

1.3 Alcance

El agente produce **borradores** (ficha del incidente, evaluación de severidad, notificaciones y plan de respuesta) para revisión humana. No envía comunicaciones, no ejecuta acciones sobre sistemas y no sustituye al Oficial de Datos Personales ni a la asesoría legal. Todos los casos usados son ficticios.

2. MARCO TEÓRICO Y NORMATIVO

2.1 Evento, incidente y brecha

La distinción entre estos tres conceptos es la primera decisión del proceso y la que más errores provoca:

Tabla 1. Conceptos base

Concepto	Definición	Fuente
Evento de seguridad	Ocurrencia que indica una posible vulneración o falla de controles. Ej.: un correo de phishing bloqueado.	ISO/IEC 27035-1
Incidente de seguridad	Uno o varios eventos con probabilidad significativa de comprometer la operación o la seguridad de la información.	ISO/IEC 27035-1
Incidente de seguridad de datos personales (brecha)	«Toda vulneración de la seguridad que ocasione la destrucción, pérdida, alteración ilícita de los datos personales o la comunicación o exposición no autorizada a dichos datos».	D.S. 016-2024-JUS, art. III num. 16

2.2 ISO/IEC 27035: proceso de gestión de incidentes

La serie ISO/IEC 27035 (partes 1 y 2 de 2023, parte 3 de 2020) define el proceso de gestión de incidentes de seguridad de la información en cinco fases: **planificar y preparar**, **detectar y reportar**, **evaluar y decidir**, **responder** y **aprender lecciones**. Esta secuencia es la columna vertebral del proyecto: cada skill implementa una o más fases (Figura 1).

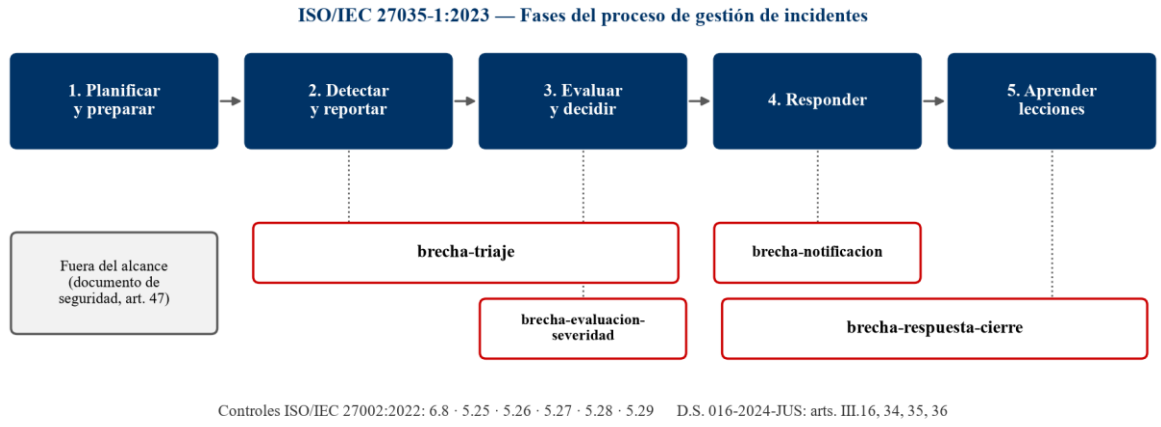


Figura 1. Fases de ISO/IEC 27035-1:2023 y skill que implementa cada una

2.3 ISO/IEC 27001, 27002 y 27701

ISO/IEC 27001:2022 establece los requisitos de un sistema de gestión de seguridad de la información; su Anexo A, desarrollado en ISO/IEC 27002:2022, contiene los controles. En el Perú se adopta como **NTP-ISO/IEC 27001:2022**, citada por el art. 48.2 del reglamento. ISO/IEC 27701 extiende ambos para datos personales (PII) y exige, en su requisito 6.13.1.5 (edición 2019), determinar si un incidente es una brecha de PII, notificar cuando corresponda y registrar cada brecha.

Tabla 2. Controles ISO/IEC 27002:2022 aplicados por los skills

Control	Nombre	Skill que lo aplica
5.24	Planificación y preparación de la gestión de incidentes	(preparación, fuera del alcance)
5.25	Evaluación y decisión sobre eventos de seguridad	brecha-triaje, brecha-evaluacion-severidad
5.26	Respuesta a incidentes de seguridad	brecha-notificacion, brecha-respuesta-cierre
5.27	Aprendizaje de los incidentes	brecha-respuesta-cierre
5.28	Recolección de evidencias	brecha-respuesta-cierre
5.29	Seguridad durante una disrupción	brecha-respuesta-cierre
5.34	Privacidad y protección de datos personales	todos
6.8	Reporte de eventos de seguridad	brecha-triaje
8.13 / 8.15 / 8.16	Respaldo, registro (logs) y monitoreo	brecha-triaje, brecha-respuesta-cierre

2.4 NIST SP 800-61 Rev. 3 e ISO/IEC 27037

La publicación **NIST SP 800-61 Rev. 3** (abril de 2025) alinea la respuesta a incidentes con las funciones del NIST Cybersecurity Framework 2.0 (Govern, Identify, Protect, Detect, Respond, Recover). El proyecto la usa para las funciones de detección, respuesta y recuperación. **ISO/IEC 27037:2012** da directrices para identificar, recolectar, adquirir y preservar evidencia digital con cadena de custodia; el skill de respuesta la aplica para que la contención no destruya evidencia.

2.5 Marco legal peruano: D.S. N.° 016-2024-JUS

El reglamento fue publicado en *El Peruano* el 30 de noviembre de 2024 y entró en vigencia a los 120 días calendario. Sus artículos 34 a 36 regulan los incidentes. Los textos se citaron literalmente del documento oficial en la base de conocimiento del proyecto.

Tabla 3. Obligaciones ante un incidente de seguridad de datos personales

Obligación	Plazo / condición	Artículo
Notificar a la ANPD	Máximo 48 h desde que se tomó conocimiento, si se cumple alguno de los supuestos del art. 34.1. Se mantiene aunque el incidente ya se haya resuelto	34.1

Obligación	Plazo / condición	Artículo
Contenido mínimo de la notificación	Naturaleza (tipos de datos, n.° de titulares), contacto del Oficial, consecuencias, medidas adoptadas o propuestas	34.2
Comunicar a los titulares	48 h, en lenguaje sencillo y claro, si el incidente afecta otros derechos del titular	34.3
Excepción para titulares	No se comunica si no hubo esa afectación y el incidente fue superado totalmente	34.4
Notificar al CNSD	Además de la ANPD, si ocurrió en o mediante el entorno digital (D.U. 007-2020)	34.5
Documentar	Siempre: hechos, efectos y medidas	35
Aviso del encargado	De forma inmediata al responsable del tratamiento	36

Los supuestos del art. 34.1 que obligan a notificar a la ANPD son, basta uno: (1) exposición de **grandes volúmenes** de datos, en cantidad o tipo; (2) posibilidad de afectar a un **gran número de personas**; (3) **datos sensibles**; (4) **perjuicio evidente** a otros derechos o libertades del titular. El reglamento no fija umbrales numéricos; la ANPD debe emitir lineamientos (art. 34.7).

2.6 Metodología de severidad ENISA

Para medir el daño a los titulares se adoptó la metodología de la Agencia de la Unión Europea para la Ciberseguridad (**ENISA**, 2013), que calcula la severidad como **SE = DPC × EI + CB**, donde DPC es el contexto de los datos (1 a 4: simples, de comportamiento, financieros, sensibles), EI la facilidad de identificación (0,25 a 1) y CB la suma de las circunstancias (pérdida de confidencialidad, integridad, disponibilidad e intención maliciosa). El resultado se clasifica en Baja (< 2), Media (2 a < 3), Alta (3 a < 4) y Muy alta (≥ 4).

En el proyecto, la severidad **apoya** la decisión pero no la reemplaza: la obligación legal se evalúa supuesto por supuesto del art. 34.1, y ante la duda se recomienda notificar.

2.7 Skills y agentes de IA

El proyecto se implementó en **Claude Code**, el entorno agéntico de Anthropic. En este entorno:

- Un **skill** es una carpeta con un archivo `SKILL.md` que contiene un encabezado YAML (`name` y `description`) y las instrucciones del procedimiento. La `description` es lo que el modelo lee para decidir **cuándo activar** el skill.
- Un **agente** (subagente) es un archivo en `.claude/agents/` con identidad, instrucciones, herramientas permitidas y los skills que puede usar. Decide qué skills ejecutar según la entrada.
- Un **comando** es un archivo en `.claude/commands/` que lanza un flujo con una sola instrucción, por ejemplo `/gestionar-incidente`.

3. DE PROMPT A SKILL

La primera tarea del trabajo fue transformar las consultas improvisadas que se hacen cuando ocurre un incidente en procesos reutilizables.

3.1 Prompts originales

Tabla 4. Prompts de partida

#	Prompt suelto
1	«Nos hackearon, ¿qué hacemos?»
2	«¿Esto es grave? ¿Tenemos que avisar a alguien?»
3	«Escríbeme un correo para avisar a los clientes que se filtraron sus datos.»
4	«Hazme un informe de lo que pasó.»

3.2 Carencias detectadas

Al ejecutar estos prompts con los casos ficticios se observaron las siguientes fallas:

Tabla 5. Carencias del prompt suelto

Carencia	Consecuencia observada
No distinguía evento, incidente y brecha	Trataba un phishing bloqueado como brecha, o un correo mal enviado como «no pasó nada»
Sin reloj	No calculaba el plazo de 48 h ni preguntaba cuándo se tomó conocimiento
Sin criterio de severidad	«Es grave» o «es leve» sin justificación reproducible
Marco legal genérico o extranjero	Citaba el RGPD europeo (72 h) en lugar del D.S. 016-2024-JUS (48 h)
Sin contenido mínimo	La notificación omitía el punto de contacto o las medidas (art. 34.2)
Destruía evidencia	Recomendaba «formatear y restaurar» antes de preservar registros y discos
Sin registro	No dejaba la documentación que exige el art. 35

3.3 Proceso de transformación

1. **Ejecutar** cada prompt con un caso ficticio y anotar las fallas.
2. **Mapear la tarea a un estándar**: las fases de ISO/IEC 27035-1 dieron la secuencia natural de pasos.
3. **Descomponer** cada fase en los pasos que seguiría un analista de respuesta a incidentes.
4. **Externalizar los criterios** en archivos de conocimiento: definición legal, supuestos del art. 34.1, fórmula ENISA y taxonomía.
5. **Fijar la salida** con plantillas: ficha, evaluación, notificación e informe de cierre.

6. **Añadir reglas**: no inventar, primero el reloj, ante la duda notificar, borrador para revisión humana.
7. **Definir la activación** con descripciones precisas.
8. **Probar y ajustar** con casos distintos.

3.4 Resultado

Tabla 6. De prompt a skill

Prompt original	Skill resultante	Fase ISO/IEC 27035
1 (parte «¿qué es?»)	brecha-triaje	Detectar y reportar / Evaluar y decidir
2	brecha-evaluacion-severidad	Evaluar y decidir
3	brecha-notificacion	Responder
1 (parte «¿qué hacemos?») y 4	brecha-respuesta-cierre	Responder / Aprender lecciones

4. CREACIÓN DE LOS SKILLS

4.1 Anatomía de un skill

Cada skill vive en su propia carpeta dentro de `.claude/skills/` y contiene el archivo de instrucciones y una o más plantillas de salida:

```
.claude/skills/brecha-triaje/
├── SKILL.md            # encabezado YAML + procedimiento
└── plantilla-ficha.md  # formato fijo de la salida
```

El encabezado YAML define la **activación**. Por ejemplo, el del skill de triaje:

```
---
name: brecha-triaje
description: Recibe el reporte de un evento o posible incidente de seguridad
  (correo enviado por error, ransomware, laptop robada, acceso indebido,
  phishing, aviso de un proveedor) y determina si es un evento, un incidente
  de seguridad o una brecha de datos personales. [...] Úsalo cuando alguien
  reporte algo que "pasó" con información o sistemas, aunque no diga
  "incidente" ni "brecha".
---
```

El cuerpo del `SKILL.md` sigue siempre la misma estructura: **sustento normativo**, **cuándo se activa**, **entradas**, **pasos numerados**, **reglas** y **salida**.

4.2 Activación de los skills

Tabla 7. Activación, entradas y salidas

Skill	Se activa cuando…	Entrada	Salida
brecha-triaje	alguien reporta que «pasó algo» con información o sistemas	Reporte libre	01-ficha-incidente.md
brecha-evaluacion-severidad	preguntan qué tan grave es o si hay que notificar	Ficha	02-evaluacion-severidad.md

Skill	Se activa cuando…	Entrada	Salida
brecha-notificacion	piden notificar o avisar a los afectados	Ficha + evaluación	03-notificacion-anpd.md, 03-comunicacion-titulares.md, 03-aviso-cnsd.md
brecha-respuesta-cierre	piden contener, un plan de respuesta, lecciones aprendidas o cerrar	Expediente	04-respuesta-y-cierre.md

4.3 Skill brecha-triaje

Propósito. Decidir si el reporte es un evento, un incidente o una brecha de datos personales, clasificarlo, priorizarlo y poner en marcha el reloj de 48 horas. **Sustento:** ISO/IEC 27035-1 (fases detectar/reportar y evaluar/decidir), ISO/IEC 27002 controles 6.8 y 5.25, ISO/IEC 27701 6.13.1.5, D.S. 016-2024-JUS art. III num. 16 y art. 36.

Procedimiento:

1. **Registrar** el incidente con un ID `INC-<AAAAMMDD>-<slug>` y crear su carpeta en `salidas/`.
2. **Línea de tiempo**: separar ocurrencia, toma de conocimiento y reporte. Calcular la **hora límite** de 48 h desde el momento más temprano en que alguien de la organización supo del incidente.
3. **¿Evento, incidente o brecha?** Aplicar el árbol de decisión de la taxonomía y la definición legal. Si es un evento sin incidente, se registra y se cierra.
4. **Clasificar** el tipo (confidencialidad, integridad, disponibilidad) y la categoría (malware, intrusión, fuga accidental, pérdida física, uso indebido interno, proveedor, etc.).
5. **Datos y titulares afectados**: categorías, datos sensibles, menores de edad y número aproximado.
6. **Rol del reportante**: si es un encargado del tratamiento, recordar su deber de aviso inmediato (art. 36).
7. **¿Entorno digital?** Si lo es, anticipar la notificación al CNSD (art. 34.5).
8. **Prioridad** P1 a P4.
9. **Acciones inmediatas** orientadas a contener sin destruir evidencia.
10. **Entregar** la ficha con la plantilla.

Reglas clave: distinguir hecho, inferencia y `NO INDICADO`; no concluir «no es brecha» solo porque el reportante lo dice; ante la duda sobre datos personales, tratar el caso como brecha probable.

4.4 Skill brecha-evaluacion-severidad

Propósito. Medir la severidad para los titulares y decidir, supuesto por supuesto, si hay que notificar. **Sustento:** ISO/IEC 27035-1 (evaluar y decidir), ISO/IEC 27002 control 5.25, metodología ENISA, D.S. 016-2024-JUS arts. 34.1, 34.3, 34.4, 34.5 y 35.

Procedimiento:

1. Leer la ficha y la metodología de severidad.
2. Asignar **DPC** (1 a 4) según el dato más delicado y aplicar el ajuste de contexto (±1), justificándolo.
3. Asignar **EI** (0,25 / 0,5 / 0,75 / 1).
4. Sumar **CB**: confidencialidad + integridad + disponibilidad + intención maliciosa.
5. Calcular **SE = DPC × EI + CB** y el nivel, mostrando la operación.
6. Listar las **consecuencias para los titulares** (las de la organización van en nota aparte).
7. **Decisión legal**: evaluar los cuatro supuestos del art. 34.1, la comunicación a titulares (34.3/34.4), el CNSD (34.5) y la documentación (35).
8. Repetir la **hora límite** y el tiempo restante.
9. Entregar con la plantilla.

Ejemplo de cálculo (caso del colegio): DPC = 3 (deuda de pensión, dato financiero) + 1 (menores de edad) = 4; EI = 1 (nombre y DNI); CB = 0,25 (un destinatario conocido no autorizado). **SE = 4 × 1 + 0,25 = 4,25 → Muy alta.**

4.5 Skill brecha-notificacion

Propósito. Redactar los borradores de notificación a la ANPD, de comunicación a los titulares y de aviso al CNSD. **Sustento:** ISO/IEC 27035-1 (responder), ISO/IEC 27002 control 5.26, ISO/IEC 27701 6.13.1.1 y 6.13.1.5, D.S. 016-2024-JUS arts. 34.1 a 34.5.

Procedimiento:

1. Confirmar los destinatarios según la evaluación y explicar por qué se omite alguno.
2. Redactar la **notificación a la ANPD** con los cuatro elementos mínimos del art. 34.2; si se envía fuera de plazo, incluir los motivos de la demora; si falta información, emitir una notificación inicial y anunciar una complementaria.
3. Redactar la **comunicación a los titulares** en lenguaje claro: qué pasó, qué datos, qué hizo la organización, qué puede hacer la persona y a quién contactar.
4. Redactar el **aviso al CNSD** cuando el incidente ocurrió en el entorno digital.
5. Verificar en una tabla que cada elemento del art. 34.2 está incluido.
6. Entregar los borradores.

Reglas clave: el agente nunca envía nada; no incluye datos personales de los afectados; no promete resultados sin evidencia ni admite responsabilidad legal; cada borrador cierra con «No enviar sin aprobación».

4.6 Skill brecha-respuesta-cierre

Propósito. Elaborar el plan de respuesta y el informe de cierre. **Sustento:** ISO/IEC 27035-1 y 27035-3 (responder y aprender lecciones), ISO/IEC 27002 controles 5.26 a 5.29 y 8.13, ISO/IEC 27037, NIST SP 800-61r3, D.S. 016-2024-JUS art. 35.

Procedimiento:

1. **Contención** de corto y largo plazo, indicando si cada acción afecta la evidencia.
2. **Preservación de evidencia**: qué recolectar, cómo preservarla (copia, hash SHA-256) y cadena de custodia. Primero preservar, luego erradicar.
3. **Erradicación** de la causa.
4. **Recuperación** desde respaldos verificados.
5. **Causa raíz** con la técnica de los 5 porqués (técnica, de proceso y humana).
6. **Lecciones aprendidas** y controles ISO/IEC 27002 propuestos con su número.
7. **Registro** del incidente exigido por el art. 35.
8. **Criterios de cierre**.
9. Entregar con la plantilla.

5. CONSTRUCCIÓN DEL ASISTENTE

Un skill funcional especializado requiere tres ingredientes: identidad, instrucciones y conocimiento.

Tabla 8. Ingredientes del asistente

Ingrediente	Implementación
Identidad	Analista de respuesta a incidentes de privacidad que apoya al Oficial de Datos Personales y al responsable de seguridad. Tono calmado y metódico con el equipo; claro y empático con los titulares. Prioriza a las personas afectadas y el plazo legal.
Instrucciones	Pasos, reglas y plantillas de cada SKILL.md; reglas globales del agente: primero el reloj, ante la duda notificar, no destruir evidencia, nunca enviar.
Conocimiento	Carpeta knowledge/ con cuatro archivos (Tabla 9).

Tabla 9. Base de conocimiento

Archivo	Contenido	Fuente
marco-normativo-peru.md	Definición legal, arts. 34 a 36 citados literalmente, criterio de inicio del plazo, medidas de seguridad (arts. 46 a 48), sanción	D.S. 016-2024-JUS (texto oficial)

Archivo	Contenido	Fuente
estandares-incidentes.md	Fases ISO/IEC 27035, controles ISO/IEC 27002:2022, ISO/IEC 27701, NIST SP 800-61r3, ISO/IEC 27037 y tabla de correspondencia	Normas ISO y NIST
metodologia-severidad.md	Fórmula SE = DPC × EI + CB y regla de decisión peruana	ENISA (2013) + art. 34.1
taxonomia-incidentes.md	Tipos CID, categorías, árbol evento/incidente/brecha, prioridades	ENISA/CSIRT, ISO/IEC 27035

Separar el conocimiento de las instrucciones permite actualizar una norma en un solo lugar y que los cuatro skills la usen. Las marcas `[VERIFICAR]` y `NO INDICADO` evitan que el modelo invente plazos, artículos o datos.

6. DISEÑO DEL AGENTE Y ORQUESTACIÓN

6.1 Ficha del agente

Tabla 10. Ficha del agente-incidentes-brechas

Elemento	Definición
Objetivo	Convertir el reporte de un incidente en un expediente trazable sin perder el plazo de 48 h
Usuarios	Oficial de Datos Personales, responsable de seguridad, equipo de respuesta a incidentes
Herramientas	Read, Glob, Grep (lectura); Write solo en salidas/. Sin red, sin comandos, sin envío
Skills	brecha-triaje, brecha-evaluacion-severidad, brecha-notificacion, brecha-respuesta-cierre
Salidas	Carpeta salidas/<ID>/ con los archivos 00 a 04
Comando	/gestionar-incidente <reporte>

6.2 Flujo de decisión

El agente sigue el ciclo de ISO/IEC 27035 y decide el camino según el resultado de cada paso (Figura 2).

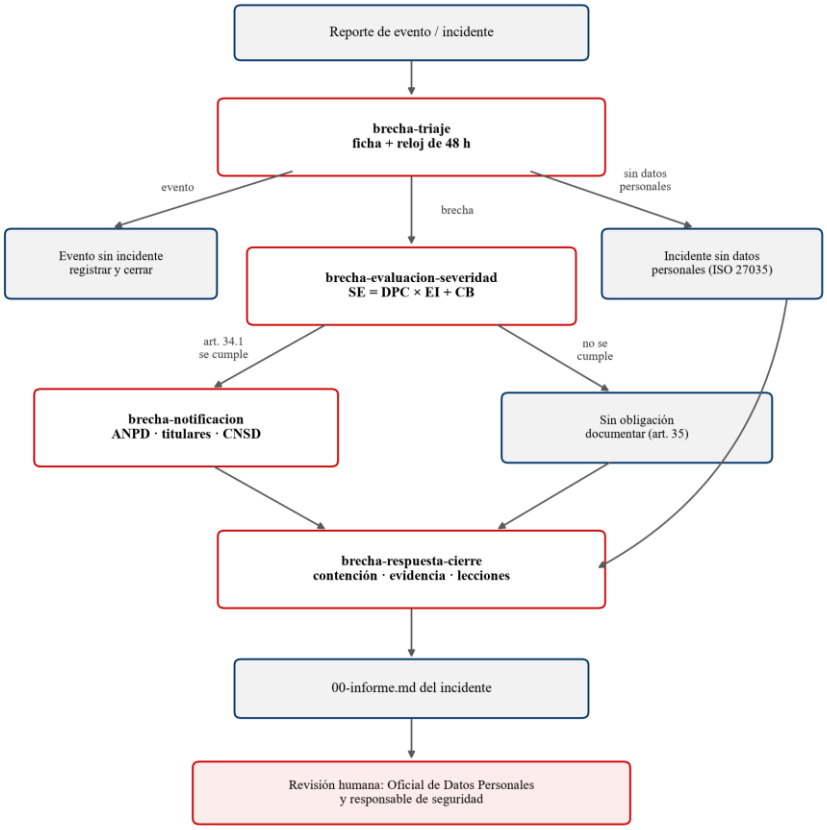


Figura 2. Flujo de decisión del agente

6.3 Traspaso entre skills

Los skills se comunican mediante archivos en la carpeta del incidente. Esa carpeta es, a la vez, el registro que exige el art. 35:

```
salidas/INC-20260929-ransomware-clinica/
├── 00-informe.md                <- agente (resumen y decisiones pendientes)
├── 01-ficha-incidente.md        <- brecha-triaje
├── 02-evaluacion-severidad.md   <- brecha-evaluacion-severidad (lee 01)
├── 03-notificacion-anpd.md      <- brecha-notificacion (lee 01 y 02)
├── 03-comunicacion-titulares.md
├── 03-aviso-cnsd.md
└── 04-respuesta-y-cierre.md     <- brecha-respuesta-cierre (lee todo)
```

6.4 Autonomía y control humano

Tabla 11. Límites de autonomía

Puede hacer solo	Requiere un humano
Clasificar y puntuar el incidente	Confirmar los hechos y la hora de conocimiento
Calcular plazos	Decidir si se notifica
Redactar borradores de notificación	Enviar cualquier notificación o comunicación
Proponer contención y controles	Ejecutar acciones técnicas sobre los sistemas
Escribir el expediente en salidas/	Aprobar el cierre del incidente

Hay cuatro puntos de control humano: tras el triaje (confirmar hechos), tras la severidad (decidir la notificación), antes de enviar (aprobar los borradores) y al cierre (aprobar las lecciones aprendidas).

7. PRUEBAS Y RESULTADOS

7.1 Casos de prueba

Tabla 12. Casos ficticios

Caso	Descripción	Qué pone a prueba
1. Ransomware en una clínica	18 000 pacientes, datos de salud cifrados y amenaza de publicación; respaldo conectado al servidor	Severidad máxima, tres notificaciones, contención sin destruir evidencia
2. Correo equivocado en un colegio	Excel con 420 alumnos menores, notas y deudas enviado a la empresa de fotos	Hora límite desde la toma de conocimiento y no desde el envío
3. Laptop robada en una cooperativa	1 500 socios con ingresos (dato sensible); cifrado desconocido; sesión de correo abierta	Manejo de información incompleta
4. Phishing bloqueado (control)	Nadie hizo clic; el dominio se bloqueó	Que el agente no sobrerreaccione: no debe notificar

7.2 Resultados

Las pruebas PR-01 a PR-04 ejecutaron el agente completo; PR-05 a PR-08 probaron cada skill por separado; PR-09 y PR-10 probaron el comando de punta a punta y el cálculo del tiempo restante.

Tabla 13. Registro de pruebas

ID	Prueba	Resultado obtenido	¿Pasó?
PR-01	Agente completo – caso 1 (ransomware)	Brecha MAL, P1. SE = 4 × 1 + 1,75 = 5,75 (Muy alta). Notifica a ANPD, pacientes y CNSD. Aísla sin apagar, preserva memoria y disco, no recomienda pagar el rescate. 7 archivos.	Sí
PR-02	Agente completo – caso 2 (correo equivocado)	Brecha FUG, P2. SE = 4,25 (Muy alta). Hora límite 02/10 15:30, contada desde la toma de conocimiento y no desde el envío. 7 archivos.	Sí
PR-03	Agente completo – caso 3 (laptop robada)	Brecha FIS + riesgo INT, P1. SE = 5,0; calculó también el escenario con cifrado (1,5). ANPD obligatoria por dato sensible (ingresos).	Sí
PR-04	Agente completo – caso 4 (control)	Evento sin incidente, P4. Se detuvo en el triaje: sin severidad ni notificación.	Sí
PR-05	Activación de brecha-triaje con lenguaje natural	«Se nos perdió una USB con las planillas» activó el skill correcto sin nombrarlo. Marcó la hora de conocimiento como NO INDICADO y la dejó como pregunta crítica.	Sí

ID	Prueba	Resultado obtenido	¿Pasó?
PR-06	Reproducibilidad de brecha-evaluacion-severidad	Cálculo independiente del caso 2, sin ver el anterior: SE = 4,25, mismo resultado y misma decisión.	Sí
PR-07	brecha-notificacion aislado	Notificación ANPD con los 4 elementos del art. 34.2, comunicación en lenguaje claro y aviso al CNSD justificado.	Sí
PR-08	brecha-respuesta-cierre aislado	Causa raíz técnica, de proceso y humana; 14 controles ISO/IEC 27002 numerados; marcó qué acciones afectan la evidencia y ordenó preservar antes de contener.	Sí
PR-09	Comando /gestionar-incidente – caso 3	El comando lanzó al agente; aplicó el criterio de inicio del plazo. Hallazgo: el agente no conocía la hora actual (el plazo ya había vencido).	Sí, con hallazgo
PR-10	Comando con fecha y hora del sistema – caso 2	El comando insertó la hora real («2026-10-01 23:30 (-0500)»). Con ella el agente calculó bien el tiempo restante: 16 h 05 min hasta el 02/10 15:30.	Sí

7.3 Verificaciones transversales

- Ningún agente escribió fuera de la carpeta `salidas/`.
- Todos los archivos generados cierran con la advertencia de borrador para revisión humana.
- Todos los artículos citados (34 a 36, 39, 46 a 48, 133) están en la base de conocimiento: no se inventaron artículos.
- Las notificaciones a la ANPD incluyen los cuatro elementos del art. 34.2.
- Ninguna salida recomendó apagar o formatear equipos antes de preservar evidencia, ni pagar el rescate.
- La severidad fue **reproducible**: un cálculo independiente del caso 2 (PR-06) obtuvo el mismo resultado (4,25).

7.4 Hallazgos y mejoras incorporadas

Las pruebas revelaron tres mejoras que se incorporaron al proyecto:

1. **Inicio del plazo de 48 h.** El reglamento dice «haber tomado conocimiento o constancia», pero no precisa quién. En el caso de la laptop robada la diferencia entre contar desde el trabajador o desde su jefe era de 12 horas. Se adoptó el criterio prudente de contar desde el momento más temprano y dejar la otra lectura como referencia.
2. **Controles adicionales.** El skill de cierre propuso con transparencia controles que no estaban listados (6.7 trabajo remoto, 7.9 activos fuera de las instalaciones, 8.23 filtrado web). Se verificó que pertenecen a ISO/IEC 27002:2022 y se añadieron.
3. **Reloj del agente.** El agente no tiene acceso a la hora actual: en PR-09 indicó «quedan menos de 24 h» cuando el plazo ya había vencido. Se modificó el comando `/gestionar-incidente` para que inserte la fecha y hora del sistema, y se instruyó al

agente a no estimar el tiempo restante si no la recibe. Con la hora disponible (PR-10) el cálculo fue correcto.

8. GUÍA DE USO

Requiere Claude Code. Desde la raíz del repositorio:

```
/gestionar-incidente examples/entradas/caso-01-ransomware-clinica.md
/gestionar-incidente examples/entradas/caso-04-phishing-bloqueado.md
```

También se puede invocar un skill con lenguaje natural, por ejemplo «¿Esto es una brecha? Se nos perdió una USB con planillas» o «Redacta la notificación a la ANPD del incidente de la clínica». Los resultados quedan en `salidas/<ID>/`.

```
.
├── .claude/skills/      # 4 skills (SKILL.md + plantillas)
├── .claude/agents/      # agente-incidentes-brechas
├── .claude/commands/    # /gestionar-incidente
├── knowledge/           # normativa, estándares, severidad, taxonomía
├── examples/entradas/   # 4 casos ficticios
├── salidas/             # expedientes generados
├── docs/                # documentación por etapa
└── pruebas/             # registro y evidencias
```

9. LIMITACIONES Y TRABAJO FUTURO

- La ANPD aún no fija umbrales para «gran volumen» ni «gran número»; el agente aplica el criterio prudente de notificar ante la duda.
- Las normas ISO son de pago: la numeración de controles corresponde a las ediciones citadas y debe validarse con el texto oficial. ISO/IEC 27701:2025 reorganizó su numeración.
- El agente analiza solo lo que dice el reporte: no investiga sistemas reales ni accede a registros.
- No sustituye al Oficial de Datos Personales, al equipo de TI ni a la asesoría legal.

Como trabajo futuro se propone: recibir reportes desde un buzón o formulario, alertas automáticas cuando falten 12 horas para la hora límite, integración con el SIEM o el sistema de tickets, y un skill de simulacros (*tabletop*) basado en ISO/IEC 27035-2.

10. CONCLUSIONES

1. Transformar los prompts sueltos en skills con pasos, criterios externos y plantillas produjo resultados **consistentes y reproducibles**: dos ejecuciones independientes del mismo caso obtuvieron la misma severidad.
2. Usar las fases de **ISO/IEC 27035** como base para dividir el trabajo dio a cada skill un sustento normativo claro y permitió usarlos de forma encadenada o por separado.

3. Citar literalmente el **D.S. 016-2024-JUS** en la base de conocimiento evitó que el modelo inventara plazos o artículos y permitió cumplir el contenido mínimo de la notificación (art. 34.2).
4. El agente **decide el camino** según el caso: cerró el phishing bloqueado en el triaje y llevó los tres casos de brecha hasta las notificaciones, con la hora límite calculada.
5. Mantener al humano en las decisiones críticas (notificar, enviar, cerrar) es indispensable: el agente acelera el trabajo y reduce omisiones, pero la responsabilidad legal sigue siendo de la organización.

11. REFERENCIAS

- Decreto Supremo N.° 016-2024-JUS. Reglamento de la Ley N.° 29733, Ley de Protección de Datos Personales. *Diario Oficial El Peruano*, 30 de noviembre de 2024.
- Ley N.° 29733, Ley de Protección de Datos Personales. Congreso de la República del Perú, 2011.
- Decreto de Urgencia N.° 007-2020, que aprueba el Marco de Confianza Digital. 2020.
- ISO/IEC 27035-1:2023. *Information security incident management — Part 1: Principles and process*.
- ISO/IEC 27035-2:2023. *Information security incident management — Part 2: Guidelines to plan and prepare for incident response*.
- ISO/IEC 27001:2022 e ISO/IEC 27002:2022. *Information security, cybersecurity and privacy protection*.
- ISO/IEC 27701:2019. *Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management*.
- ISO/IEC 27037:2012. *Guidelines for identification, collection, acquisition and preservation of digital evidence*.
- NIST (2025). *SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management*.
- ENISA (2013). *Recommendations for a methodology of the assessment of severity of personal data breaches*.
- Anthropic (2026). *Claude Code: documentación de skills, subagentes y comandos*.